WEB SECURITY & PENETRATION TESTING ROADMAP

A Practical, Beginner-Friendly Learning and Professional Development Plan

Name	Girma Tamene
ID	CTC-4421-26
Department	Cyber Security
Document purpose	Self-learning roadmap and progress plan

Prepared as a structured guide for learning, practical lab work, documentation, and ongoing skill development.

1. Introduction

My penetration testing journey began with independent research into web security. I started by searching for information online and organizing the concepts into a roadmap that presents the topics in a logical learning order. The purpose of this roadmap is to build cybersecurity knowledge step by step, beginning with foundational concepts and progressing toward practical web application testing.

This document reflects an initial period of approximately two months of self-directed learning in web security, undertaken to develop practical cybersecurity skills. It combines theory, authorized hands-on exercises, tool practice, documentation, and review. The roadmap is intended to guide continued development; completing a particular period of study does not by itself demonstrate professional or senior-level competence.

2. Learning Objectives

- Understand networking, HTTP/HTTPS, Linux, and the technologies used by web applications.
- Learn common web application vulnerabilities and the concepts covered by the OWASP Top 10.
- Develop practical skills with Kali Linux, Nmap, Burp Suite, and selected content-discovery tools.
- Practice reconnaissance, enumeration, vulnerability validation, and remediation in authorized environments.
- Learn to document findings clearly and prepare structured penetration testing reports.
- Build a portfolio containing lab notes, write-ups, scripts, checklists, and reports that do not expose sensitive information.
- Progress from beginner foundations toward intermediate and advanced web security skills through consistent practice.

3. How to Use This Roadmap

- Work through the learning levels in order, while revisiting earlier topics when necessary.
- Study the theory, practice in a legal lab, document the results, and explain the concept in your own words.
- Use a notebook, Obsidian, Notion, or a private GitHub repository to record notes and progress.
- Do not move on merely because a lesson is complete; confirm that you can explain the topic and interpret the practical results.
- A suggested pace is approximately 1–2 hours per day. The original roadmap estimates around 9–12 months to work toward job-ready or bug-bounty-ready skills, but actual progress depends on prior knowledge, practice quality, and experience.
- Some learning-platform rooms may require a paid subscription or may change location. If a room is unavailable, search for its title on the platform or use an equivalent free PortSwigger Web Security Academy lab where suitable.
- .

5. Roadmap Overview

Stage	Focus	Suggested timeline
1	Computer, networking, web, Linux, and programming foundations	Weeks 1–4
2	Linux and web technologies; HTTP, forms, sessions, and databases	Weeks 5–8
3	Reconnaissance, enumeration, and essential tools	Months 3–4
4	Core web vulnerabilities and guided labs	Months 4–6
5	Structured web assessments, methodology, and reporting	Months 6–9

6	Advanced web security topics and independent lab work	Months 9–12
7	Professional development, portfolio, and continued specialization	Months 12–18+

The source roadmap also groups these activities into six broad workstreams: foundations; OWASP-related web vulnerabilities; tools; ongoing legal practice; methodology and reporting; and specialization through a portfolio, bug bounty work, or certifications. The seven learning levels below provide a more detailed sequence.

6. Detailed Learning Roadmap

Level 1: Computer and Web Fundamentals (Weeks 1–4)

Goal: Understand how networks, the internet, and web applications work before testing them.

Topics to study

- Networking: OSI and TCP/IP models; IP addresses, subnets, and ports; DNS, DHCP, and ARP; TCP versus UDP; TCP three-way handshake; HTTP/HTTPS and basic TLS.
- Web fundamentals: HTML, CSS, and JavaScript basics; GET, POST, PUT, and DELETE; HTTP status codes and headers; cookies, sessions, and JWT concepts; browser-to-server request flow; Same-Origin Policy and CORS.
- Linux: Install Kali Linux or Parrot OS in a virtual machine; navigate directories; understand file permissions, users, and groups; learn basic Bash, pipes, grep, curl, wget, and apt.
- Programming and databases: Python variables, loops, functions, requests, and file handling; SQL SELECT, WHERE, JOIN, and UNION.

Learning resources

- TryHackMe Pre Security: https://tryhackme.com/path/outline/presecurity
- TryHackMe Offensive Security Intro: https://tryhackme.com/ (search for “Offensive Security Intro” if the room link changes).
- Linux Journey: https://linuxjourney.com/
- OverTheWire Bandit: https://overthewire.org/wargames/bandit/
- MDN Web Development: https://developer.mozilla.org/en-US/docs/Learn_web_development
- freeCodeCamp: https://www.freecodecamp.org/
- Automate the Boring Stuff with Python: https://automatetheboringstuff.com/
- Cisco Networking Academy: https://www.netacad.com/

Completion checklist

- Explain what happens when a URL is entered into a browser.
- Read a basic HTTP request and response and identify their main parts.
- Use the Linux terminal for common navigation and file operations.
- Write a small Python script that sends a web request in a controlled environment.
- Write and explain basic SQL queries.

Level 2: Linux and Web Technologies (Weeks 5–8)

Goal: Become more comfortable inspecting web traffic and understanding how web applications process user input.

- Use browser Developer Tools, especially the Network tab, to inspect requests and responses.
- Understand HTTP methods, status codes, request headers, response headers, forms, authentication, and session handling.

- Learn the basic security considerations of PHP and MySQL applications, including parameterized queries and server-side validation.
- Practice reading request/response flows in a local application rather than testing systems without permission.

Learning resources

- TryHackMe Cyber Security 101: https://tryhackme.com/path/outline/cybersecurity101
- PortSwigger Web Security Academy: https://portswigger.net/web-security
- picoCTF: https://picoctf.org/

Milestone: Build or inspect a simple local web application and explain its requests, responses, and database queries.

Level 3: Reconnaissance and Enumeration (Months 3–4)

Goal: Learn to map the exposed surface of an authorized target and identify technologies and endpoints.

- Define the authorized scope and record the target information that is permitted to be tested.
- Learn DNS enumeration and subdomain discovery within the approved scope.
- Identify web technologies and frameworks using appropriate tools.
- Practice directory and content discovery with Gobuster or ffuf in training labs.
- Learn Nmap port scanning and service identification in authorized environments.
- Use Burp Suite Proxy, HTTP history, and Repeater to inspect and replay requests.

Learning resources

- TryHackMe Jr Penetration Tester: https://tryhackme.com/path/outline/jrpenetrationtester
- Burp Suite Getting Started: https://portswigger.net/burp/documentation/desktop/getting-started
- Nmap Reference Guide: https://nmap.org/book/man.html
- TryHackMe: search for “Enumeration” and “Intro to Web Hacking” if room links change.

Milestone: Produce an attack-surface map for an authorized lab and document the technologies, services, and endpoints found.

Level 4: Core Web Vulnerabilities (Months 4–6)

Goal: Understand how common web vulnerabilities arise, how to validate them safely in labs, and how to prevent them.

Vulnerability	Core idea	Typical prevention
SQL Injection (SQLi)	User input changes the intended database query.	Use parameterized queries and avoid unsafe query construction.
Cross-Site Scripting (XSS)	Untrusted input is interpreted as executable script in a browser.	Use context-aware output encoding and suitable content security controls.
Broken Authentication	Weak login, password-reset, or session logic.	Use secure authentication, strong session handling, and MFA where appropriate.
Broken Access Control / IDOR	A user accesses data or actions beyond their authorization.	Enforce server-side authorization on every relevant request.
Cross-Site Request Forgery (CSRF)	A victim’s authenticated browser is induced to send an unintended request.	Use anti-CSRF protections and appropriate cookie settings.
Server-Side Request Forgery (SSRF)	A server is induced to make unintended requests.	Apply destination allowlists, network segmentation, and request controls.
File Upload / Path Traversal / File Inclusion	File handling permits unsafe uploads or unintended file access.	Validate uploads, store files safely, and normalize and validate paths.
Security Misconfiguration	Unsafe defaults, exposed services, or excessive error details.	Harden configuration, remove defaults, and apply least privilege.
Command Injection	User-controlled input influences operating-system command execution.	Avoid shell execution where possible and validate inputs.
XML External Entity (XXE)	Unsafe XML parser behavior permits external entity processing.	Disable unsafe external entity processing.

Insecure Deserialization	Untrusted serialized data is handled unsafely.	Avoid unsafe deserialization and validate data and types.
Business Logic Flaws	Application workflows can be used in unintended ways.	Enforce business rules on the server and test workflow assumptions.

How to study each vulnerability

1. Read the theory using PortSwigger and OWASP resources.
2. Attempt the lab independently before checking hints or a walkthrough.
3. Write a short note covering definition, lab demonstration, detection, impact, and mitigation.
4. Where appropriate, repeat the exercise on a local vulnerable application such as OWASP Juice Shop or DVWA.
5. Explain the vulnerability and its remediation in your own words.

Learning resources

- PortSwigger Web Security Academy: https://portswigger.net/web-security
- OWASP Top 10: https://owasp.org/www-project-top-ten/
- OWASP Cheat Sheet Series: https://cheatsheetseries.owasp.org/
- OWASP Juice Shop: https://owasp.org/www-project-juice-shop/
- Damn Vulnerable Web Application (DVWA): https://github.com/digininja/DVWA
- HackTricks reference: https://book.hacktricks.xyz/ (use as a reference after learning the fundamentals).

Completion milestone: Complete beginner-level labs for the listed topics where available, explain the vulnerability manually, describe its fix, and maintain written notes. Some rooms may be paid or may change; use equivalent free labs where appropriate.

Level 5: Tools and Practical Workflow (introduced in Weeks 8–12 and revisited thereafter)

Goal: Learn tools after understanding the concepts so that results can be interpreted rather than accepted blindly.

Tool	Purpose	Skills to develop
Burp Suite Community	Intercept and inspect web traffic.	Proxy, HTTP history, Repeater, Decoder; understand feature limitations.
Browser Developer Tools	Inspect browser requests and application behavior.	Network tab, JavaScript, cookies, storage.
Nmap	Discover ports and services.	Port scans, service/version identification, appropriate scripts.
ffuf / Gobuster	Discover paths and parameters.	Content discovery and result filtering.
SQLmap	Assist with SQL injection testing.	Use only in authorized labs and after learning manual SQL injection.
Subfinder / Amass	Discover subdomains and map an attack surface.	Stay within explicitly authorized scope.
Wappalyzer	Identify technologies used by a site.	Technology fingerprinting and understanding uncertainty.

Learning resources

- TryHackMe Burp Suite learning module and “Burp Suite: The Basics” where available.
- TryHackMe Nmap learning rooms.
- TryHackMe Intro to Web Hacking topics such as application navigation, content discovery, and subdomain enumeration.
- Burp Suite documentation: https://portswigger.net/burp/documentation

Completion checklist: Intercept, modify, and replay a lab request; run and explain an authorized Nmap scan; discover hidden paths in a lab; and explain when automation is helpful and when manual validation is necessary.

Level 6: Ongoing Legal Practice

Goal: Turn knowledge into repeatable practical skill. Practical work should continue throughout every stage.

Platform	Suggested level	Main use
TryHackMe	Beginner and beyond	Guided rooms and learning paths.
PortSwigger Web Security Academy	Beginner to advanced	Web-specific vulnerability labs.
OWASP Juice Shop / DVWA	Beginner and beyond	Local practice on deliberately vulnerable applications.
Hack The Box	Intermediate and beyond	Realistic machines and challenges.
picoCTF	Beginner	CTF-style security puzzles.
OverTheWire	Beginner	Linux and command-line skills.
PentesterLab	Intermediate and beyond	Structured web security exercises.

Practice habits

- Spend 30–60 minutes attempting a lab before reading a hint, where feasible.
- After solving it, compare your method with a walkthrough and note what you missed.
- Keep a log of every completed lab or machine.
- Record the objective, authorized scope, steps taken, results, evidence, lessons learned, and remediation.

Level 7: Assessment Methodology and Reporting (Months 3–5 onward)

Goal: Work systematically and communicate findings in a way that helps an organization understand and fix risk.

Penetration testing stages

6. Planning and scope: define targets, permissions, timing, and restrictions.
7. Reconnaissance: identify permitted domains, technologies, endpoints, and public information.
8. Scanning and enumeration: assess ports, services, parameters, and exposed content.
9. Vulnerability validation: safely confirm suspected weaknesses and collect evidence.
10. Impact assessment: explain realistic consequences without causing damage or accessing unnecessary data.
11. Reporting: describe findings clearly, with severity, evidence, and remediation.
12. Retesting: verify whether the recommended fixes resolve the issues.

Web application testing checklist

- Information gathering and technology fingerprinting.
- Configuration and deployment testing.
- Identity management and authentication testing.
- Authorization and access-control testing.
- Session-management testing.
- Input-validation testing, including SQL injection and XSS.
- Error handling and cryptography checks.
- Business logic testing.
- Client-side testing.
- API testing.

Required sections in a finding

Section	What to include
Title	Short and specific, for example: “IDOR allows viewing other users’ invoices.”
Severity	Critical, High, Medium, or Low; include a justified CVSS score if appropriate.
Description	What the issue is and where it occurs.

Steps to reproduce	Numbered, repeatable steps performed in the authorized environment.
Impact	Realistic consequences for confidentiality, integrity, or availability.
Evidence	Screenshots and relevant requests/responses with sensitive information removed.
Remediation	Specific corrective actions.
References	Relevant OWASP, CWE, or other authoritative references.

Methodology resources

- OWASP Web Security Testing Guide (WSTG): https://owasp.org/www-project-web-security-testing-guide/
- Penetration Testing Execution Standard (PTES): http://www.pentest-standard.org/
- HackerOne Hacktivity for public report examples: https://hackerone.com/hacktivity

Completion milestone: Follow a full methodology on a practice target, use a checklist for every assessment, and produce at least three complete reports.

Level 8: Advanced Web Security (Months 9–12)

Goal: Develop deeper knowledge of complex web application and API security issues.

- Server-Side Request Forgery (SSRF) and request-smuggling concepts.
- Advanced access-control flaws and race conditions.
- OAuth and OpenID Connect (OIDC) security.
- GraphQL security.
- Insecure deserialization and complex business logic testing.
- Root-cause analysis and reliable remediation guidance.

Learning resources

- PortSwigger Web Security Academy: https://portswigger.net/web-security
- OWASP Cheat Sheet Series: https://cheatsheetseries.owasp.org/
- OWASP Application Security Verification Standard (ASVS): https://owasp.org/www-project-application-security-verification-standard/

Milestone: Solve advanced labs independently, explain the root cause of each issue, and recommend fixes that address the underlying weakness.

Level 9: Professional Development and Specialization (Months 5–12 and beyond)

Goal: Build practical evidence of skill, choose a specialization, and continue toward professional-level responsibility.

Bug bounty and vulnerability disclosure

- Potential platforms include HackerOne, Bugcrowd, Intigriti, and YesWeHack.
- Begin with vulnerability disclosure programs or less crowded programs where the rules and scope are clear.
- Read the scope and policy carefully; test only permitted assets and techniques.
- Expect gradual progress. Duplicate and rejected reports can be part of the learning process.
- Consider focusing on one vulnerability class at a time, such as IDOR or XSS.

Portfolio development

- Publish write-ups of labs and CTFs on GitHub or a blog, following platform rules.
- Contribute small fixes or documentation improvements to open-source security tools.
- Share learning progress on LinkedIn or other professional channels.
- Never publish secrets, personal data, or details that violate a program’s disclosure policy.

10. Immediate Next Steps

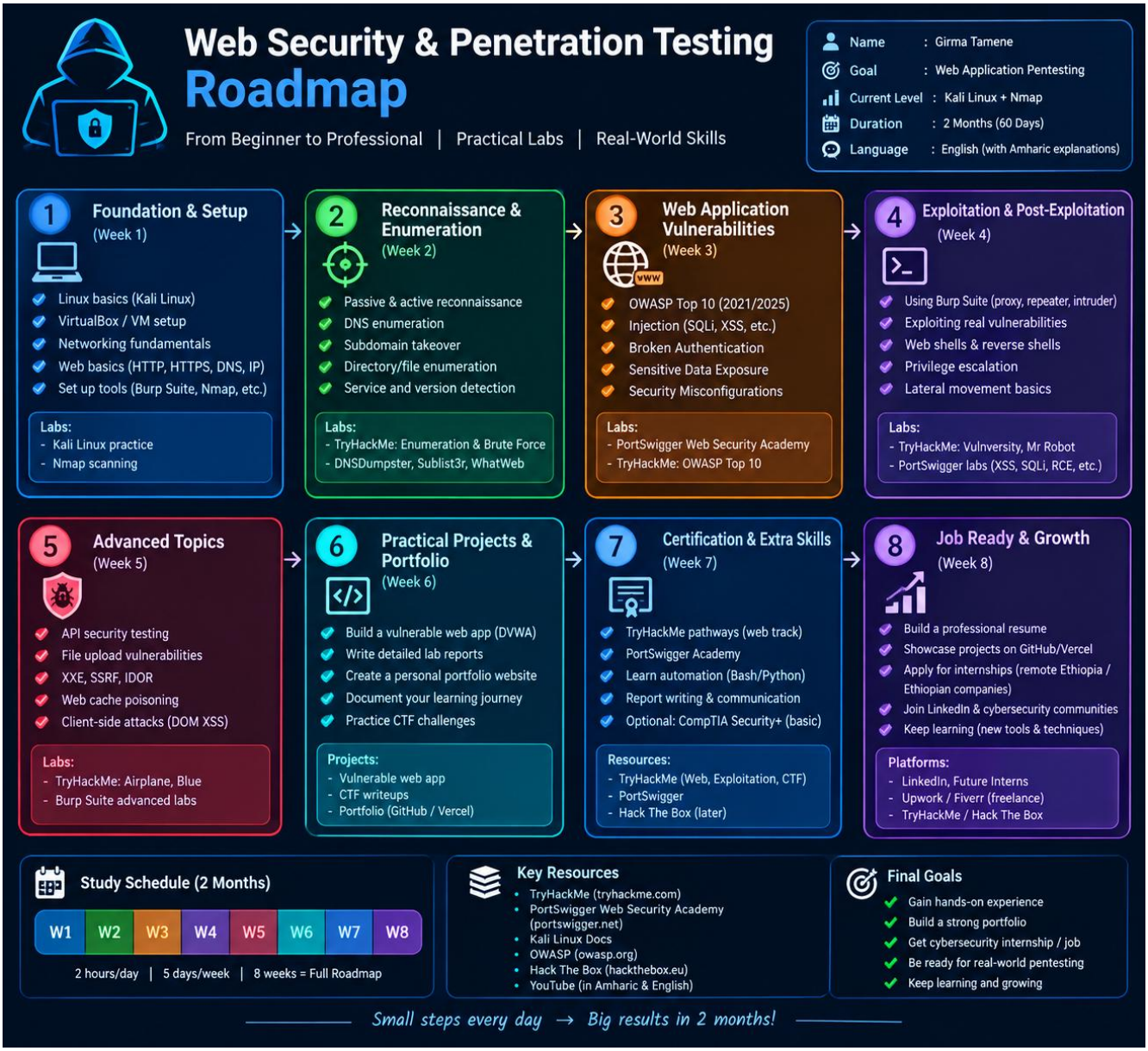
13. Set up or review a Kali Linux virtual machine and create a safe, authorized practice environment.
14. Create a GitHub account or a private notebook for learning notes and reports.
15. Start or continue the TryHackMe Pre Security learning path.
16. Create a weekly progress tracker and follow a realistic study schedule.
17. Choose one web security topic at a time and complete the corresponding practice labs.
18. Review this roadmap monthly and adjust the pace according to demonstrated understanding.

11. Conclusion

My web security and penetration testing journey is an ongoing process of learning, practical experimentation, documentation, and improvement. The initial period of approximately two months of self-directed study has helped me begin organizing my knowledge and identifying the skills I need to develop further.

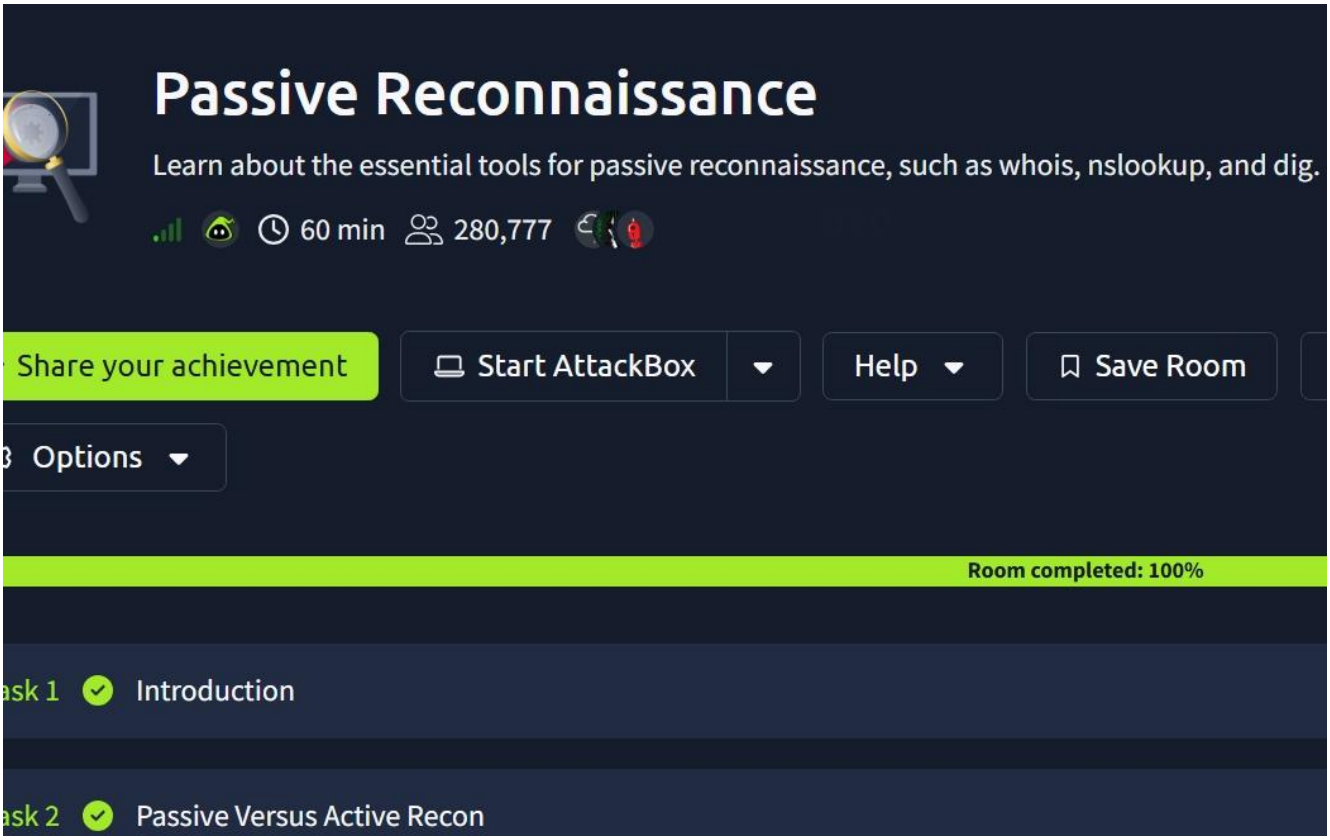
The next stage is to strengthen foundational knowledge, complete authorized hands-on labs, practice the use of essential tools, and improve the quality of my reports. Continued progress through the roadmap can help me work toward conducting structured web application security assessments and developing a professional cybersecurity portfolio.

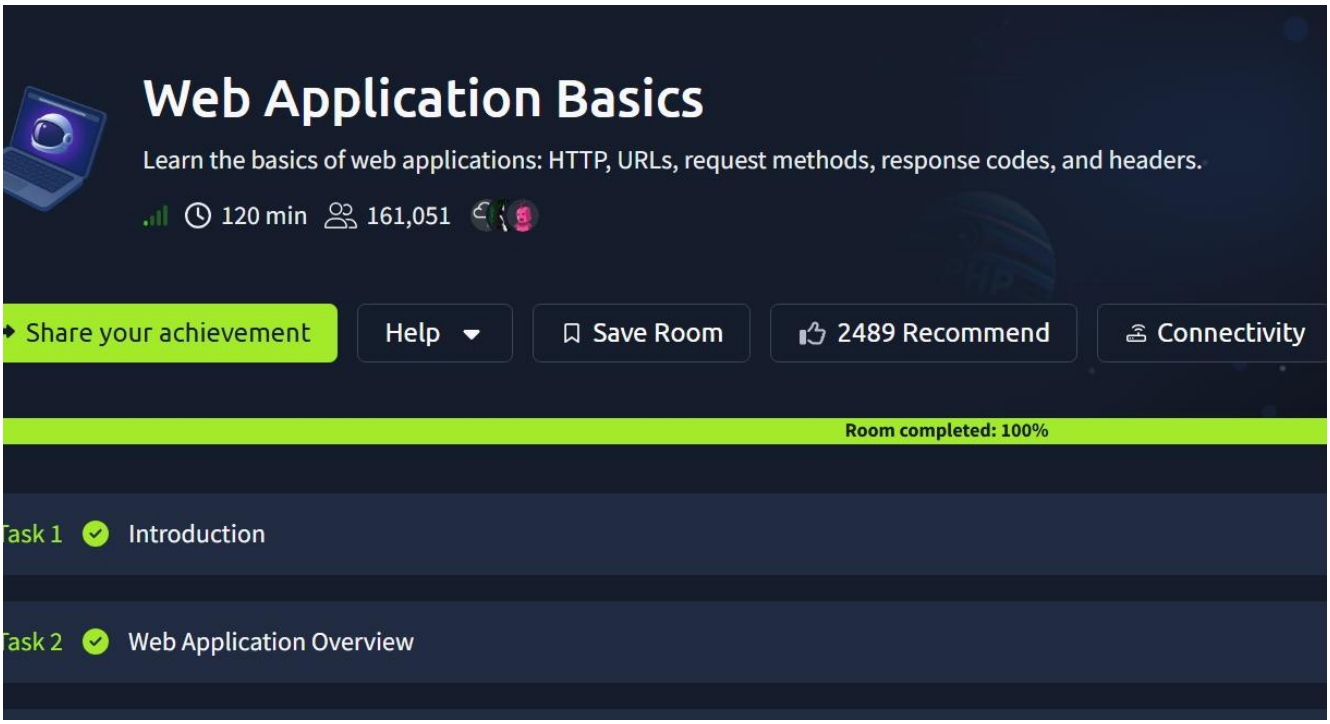
Learning principle: Understand the concept → Practice safely → Record the evidence → Explain the impact → Learn the fix → Review and improve.

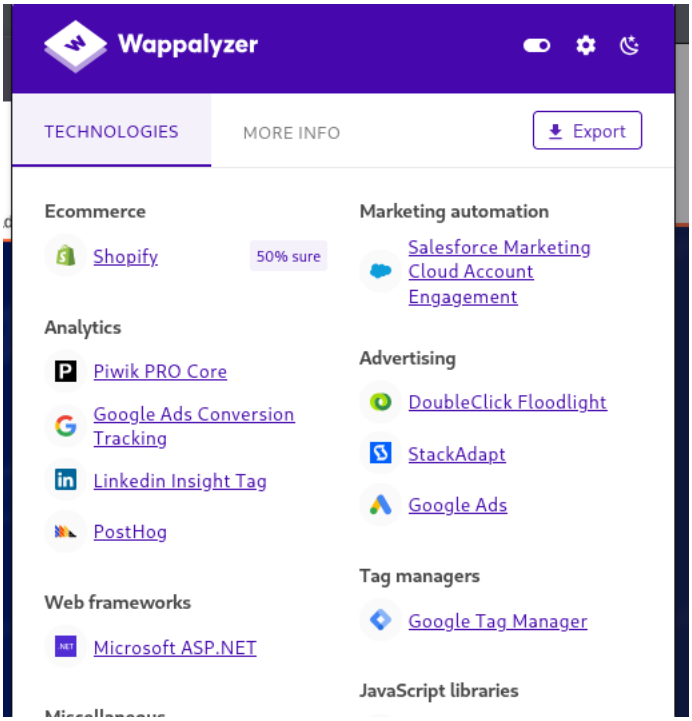

Web Security & Penetration Testing
Roadmap
From Beginner to Professional | Practical Labs | Real-World Skills
Name : Girma Tamene
Goal : Web Application Pentesting
Current Level : Kali Linux + Nmap
Duration : 2 Months (60 Days)
Language : English (with Amharic explanations)
1 Foundation & Setup
(Week 1)
Linux basics (Kali Linux)
VirtualBox / VM setup
Networking fundamentals
Web basics (HTTP, HTTPS, DNS, IP)
Set up tools (Burp Suite, Nmap, etc.)
Labs:
- Kali Linux practice
- Nmap scanning
2 Reconnaissance & Enumeration
(Week 2)
Passive & active reconnaissance
DNS enumeration
Subdomain takeover
Directory/file enumeration
Service and version detection
Labs:
- TryHackMe: Enumeration & Brute Force
- DNSDumpster, Sublist3r, WhatWeb
3 Web Application Vulnerabilities
(Week 3)
OWASP Top 10 (2021/2025)
Injection (SQLi, XSS, etc.)
Broken Authentication
Sensitive Data Exposure
Security Misconfigurations
Labs:
- PortSwigger Web Security Academy
- TryHackMe: OWASP Top 10
4 Exploitation & Post-Exploitation
(Week 4)
Using Burp Suite (proxy, repeater, intruder)
Exploiting real vulnerabilities
Web shells & reverse shells
Privilege escalation
Lateral movement basics
Labs:
- TryHackMe: Vulnversity, Mr Robot
- PortSwigger labs (XSS, SQLi, RCE, etc.)
5 Advanced Topics
(Week 5)
API security testing
File upload vulnerabilities
XXE, SSRF, IDOR
Web cache poisoning
Client-side attacks (DOM XSS)
Labs:
- TryHackMe: Airplane, Blue
- Burp Suite advanced labs
6 Practical Projects & Portfolio
(Week 6)
Build a vulnerable web app (DVWA)
Write detailed lab reports
Create a personal portfolio website
Document your learning journey
Practice CTF challenges
Projects:
- Vulnerable web app
- CTF writeups
- Portfolio (GitHub / Vercel)
7 Certification & Extra Skills
(Week 7)
TryHackMe pathways (web track)
PortSwigger Academy
Learn automation (Bash/Python)
Report writing & communication
Optional: CompTIA Security+ (basic)
Resources:
- TryHackMe (Web, Exploitation, CTF)
- PortSwigger
- Hack The Box (later)
8 Job Ready & Growth
(Week 8)
Build a professional resume
Showcase projects on GitHub/Vercel
Apply for internships (remote Ethiopia / Ethiopian companies)
Join LinkedIn & cybersecurity communities
Keep learning (new tools & techniques)
Platforms:
- LinkedIn, Future Interns
- Upwork / Fiverr (freelance)
- TryHackMe / Hack The Box
Study Schedule (2 Months)
W1 W2 W3 W4 W5 W6 W7 W8
2 hours/day | 5 days/week | 8 weeks = Full Roadmap
Key Resources
TryHackMe (tryhackme.com)
PortSwigger Web Security Academy (portswigger.net)
Kali Linux Docs
OWASP (owasp.org)
Hack The Box (hackthebox.eu)
YouTube (in Amharic & English)
Final Goals
Gain hands-on experience
Build a strong portfolio
Get cybersecurity internship / job
Be ready for real-world pentesting
Keep learning and growing
Small steps every day → Big results in 2 months!

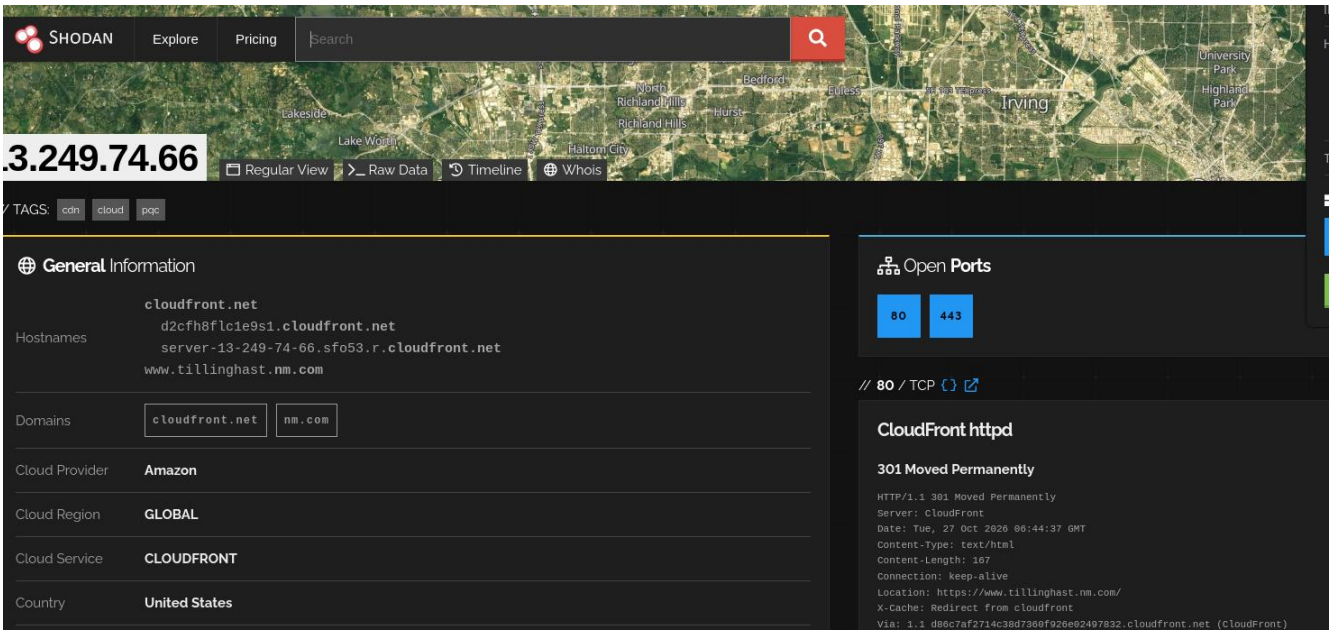

Back to all walkthroughs
SQL Injection Introduction
Learn how to detect and exploit SQL Injection vulnerabilities.
60 min
28,739
Share your achievement
Help
Save Room
382 Recommend
Room completed: 100%
Task 1
Introduction
Task 2
SQL Essentials for Injection

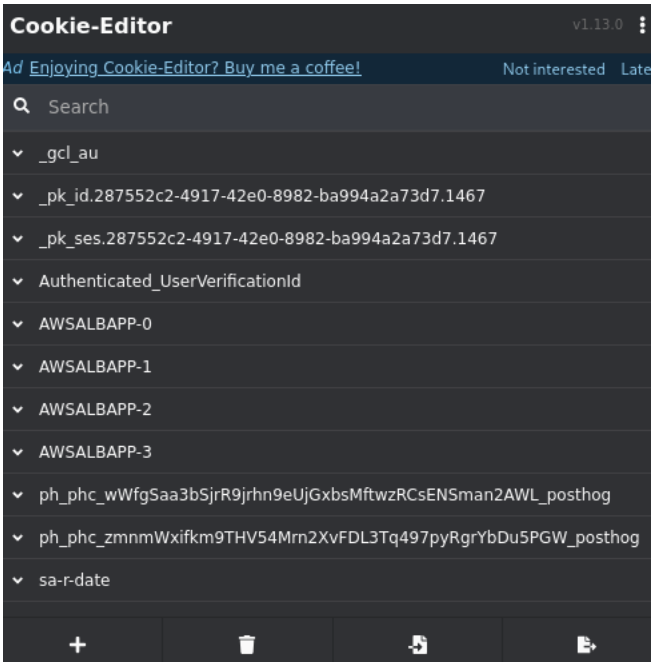

Enumeration & Brute Force
Enumerate and brute force authentication mechanisms.
30 min
153,818
Share your achievement
Start AttackBox
Help
Save Room
Options
Room completed: 100%
Task 1 Introduction
Task 2 Authentication Enumeration
Task 3 Enumerating Users via Verbose Errors
Task 4 Exploiting Vulnerable Password Reset Logic

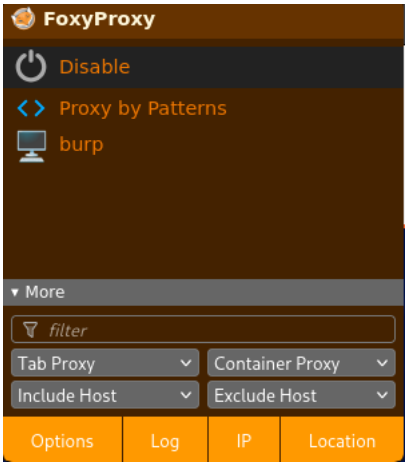

Passive Reconnaissance
Learn about the essential tools for passive reconnaissance, such as whois, nslookup, and dig.
60 min
280,777
Share your achievement
Start AttackBox
Help
Save Room
Options
Room completed: 100%
Introduction
Passive Versus Active Recon


Web Application Basics
Learn the basics of web applications: HTTP, URLs, request methods, response codes, and headers.
120 min
161,051
Share your achievement
Help
Save Room
2489 Recommend
Connectivity
Room completed: 100%
Introduction
Web Application Overview


Wappalyzer
TECHNOLOGIES
MORE INFO
Export
Ecommerce
Shopify
50% sure
Analytics
Piwik PRO Core
Google Ads Conversion Tracking
Linkedin Insight Tag
PostHog
Web frameworks
Microsoft ASP.NET
Marketing automation
Salesforce Marketing Cloud Account Engagement
Advertising
DoubleClick Floodlight
StackAdapt
Google Ads
Tag managers
Google Tag Manager
JavaScript libraries


SHODAN
Explore
Pricing
Search
.3.249.74.66
Regular View
Raw Data
Timeline
Whois
TAGS: cdn cloud pqc
General Information
Hostnames
cloudfront.net
d2cfh8flc1e9s1.cloudfront.net
server-13-249-74-66.sfo53.r.cloudfront.net
www.tillinghast.nm.com
Domains
cloudfront.net
nm.com
Cloud Provider
Amazon
Cloud Region
GLOBAL
Cloud Service
CLOUDFRONT
Country
United States
Open Ports
80
443
// 80 / TCP
CloudFront httpd
301 Moved Permanently
HTTP/1.1 301 Moved Permanently
Server: CloudFront
Date: Tue, 27 Oct 2026 06:44:37 GMT
Content-Type: text/html
Content-Length: 167
Connection: keep-alive
Location: https://www.tillinghast.nm.com/
X-Cache: Redirect from cloudfront


Cookie-Editor
v1.13.0
Ad Enjoying Cookie-Editor? Buy me a coffee!
Not interested
Late
Search
_gcl_au
_pk_id.287552c2-4917-42e0-8982-ba994a2a73d7.1467
_pk_ses.287552c2-4917-42e0-8982-ba994a2a73d7.1467
Authenticated_UserVerificationId
AWSALBAPP-0
AWSALBAPP-1
AWSALBAPP-2
AWSALBAPP-3
ph_phc_wWfgSaa3bSjrR9jrhn9eUjGxbsMftwzRCsENSman2AWL_posthog
ph_phc_zmnmWxifkm9THV54Mrn2XvFDL3Tq497pyRgrYbDu5PGW_posthog
sa-r-date


FoxyProxy
Disable
Proxy by Patterns
burp
More
filter
Tab Proxy
Container Proxy
Include Host
Exclude Host
Options
Log
IP
Location

Web Security Academy | Reflected XSS into HTML context with nothing encoded

Back to lab description

Congratulations, you solved the lab! Share your skills!

Home

0 search results for ''

Search the blog... Search

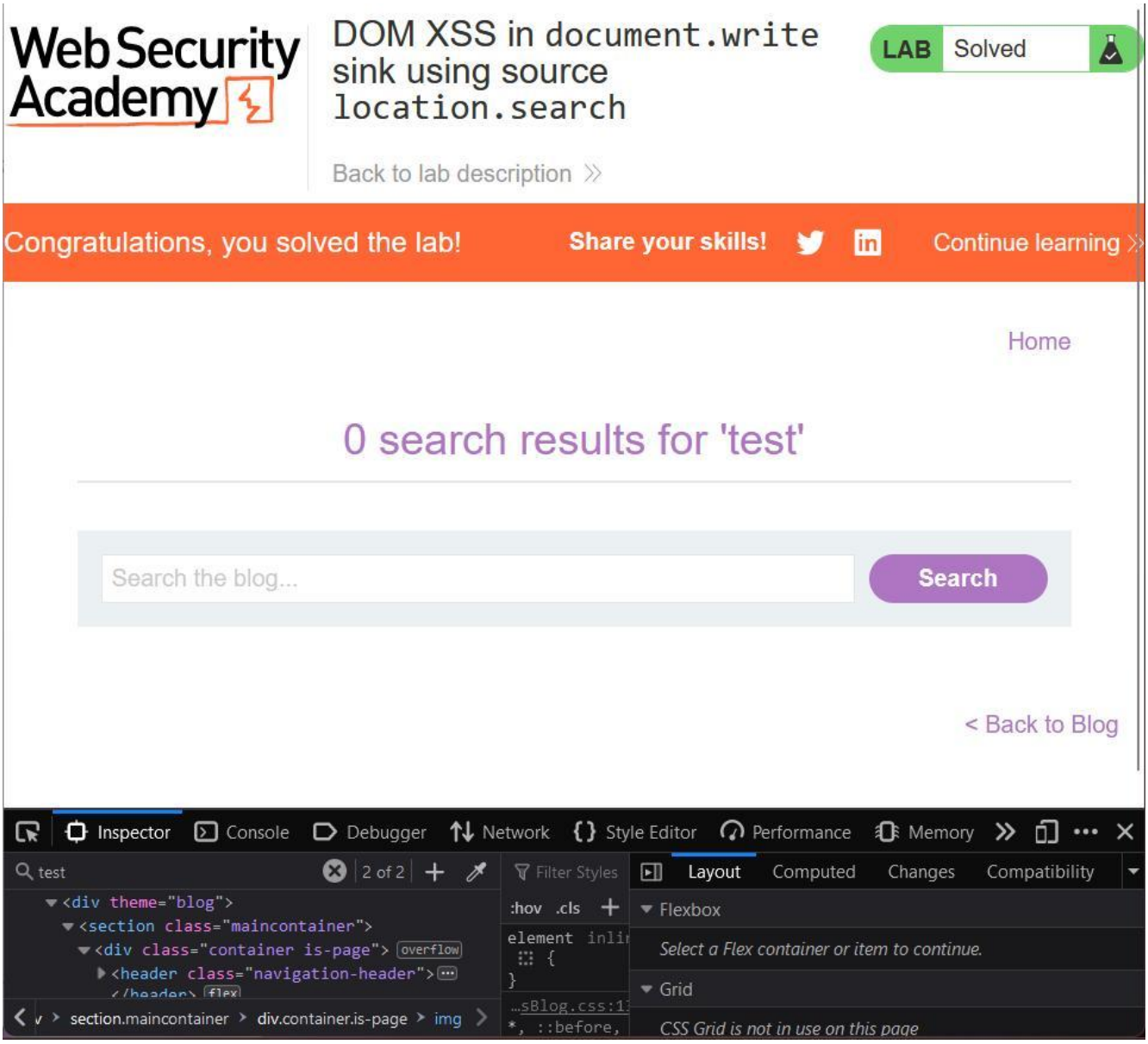
< Back to Blog

Lab: Stored XSS into HTML context with nothing encoded

APPRENTICE

LAB Solved

This lab contains a stored cross-site scripting vulnerability in the comment functionality.


Web Security Academy
DOM XSS in document.write sink using source location.search
LAB Solved
Back to lab description
Congratulations, you solved the lab!
Share your skills!
Continue learning
Home
0 search results for 'test'
Search the blog...
Search
< Back to Blog
Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
test
2 of 2
Filter Styles
Layout
Computed
Changes
Compatibility

<section class="maincontainer">

overflow
<header class="navigation-header">
:hov .cls
element
Flexbox
Select a Flex container or item to continue.
Grid
CSS Grid is not in use on this page
section.maincontainer
div.container.is-page
img